

Como o sistema confere se uma etiqueta NFC é verdadeira

As 3 estratégias de validação estudadas no TCC, explicadas em linguagem simples

- 1 NDEF estático** — a etiqueta guarda um texto fixo, como um bilhete colado na caixa.
- 2 Associação por UID** — o sistema usa o "número de série" de fábrica do chip.
- 3 Mensagem dinâmica autenticada (SDM)** — a cada leitura o chip gera um código novo, impossível de adivinhar sem a chave secreta.

Projeto: *Desenvolvimento de um Sistema de Rastreabilidade Logística baseado em NFC para Autenticação e Registro de Eventos*

Autores: Bruno Sezar Marcelino Aiolfi e João Augusto Pupo Fagundes

Orientador: Cleber Lourenço Izidoro

Material de apoio elaborado a partir do pré-projeto, do texto de Introdução e Materiais e Métodos, do escopo da v1 e do relatório de auditoria do TCC.

1. Qual é o problema?

Imagine uma encomenda que passa por várias mãos: é **cadastrada**, **coletada**, **recebida** em um centro e, por fim, **entregue**. Em cada etapa, um trabalhador aproxima o celular de uma pequena etiqueta NFC colada na caixa e o aplicativo registra o que aconteceu. Com isso, a encomenda ganha um histórico digital.

A pergunta central é: **quando o celular lê a etiqueta, como o sistema sabe que aquela leitura é verdadeira?** Alguém poderia copiar a etiqueta para outra, inventar dados no aplicativo ou reaproveitar uma leitura antiga para registrar uma movimentação que nunca aconteceu.

Para responder isso, o trabalho compara **três estratégias**, da mais simples à mais segura. Todas usam o **mesmo modelo de etiqueta** (NTAG 424 DNA), o mesmo aplicativo e o mesmo servidor. Assim, se uma estratégia se sair melhor que outra, a diferença vem da estratégia, e não do equipamento.

Três ideias que vale ter em mente

- **Identificar não é o mesmo que autenticar.** Ler um número e achar um cadastro (identificar) é diferente de provar que aquele número veio mesmo da etiqueta verdadeira (autenticar).
- **A etiqueta só garante o que ela mesma produz.** O tipo de operação ("entregue"), o horário e a localização são informados pelo aplicativo e precisam ser conferidos à parte.
- **Quem decide é o servidor.** O aplicativo lê tudo o que a etiqueta oferece e envia; o servidor é quem valida. A estratégia de cada etiqueta é definida no cadastro e não pode ser trocada pelo aplicativo — isso evita que alguém "force" o modo mais fraco.

O que é NFC, NDEF e UID (bem rápido)

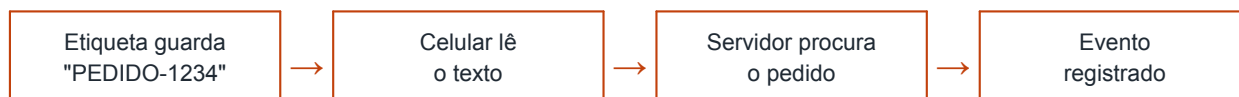
NFC	Comunicação por aproximação (poucos centímetros). É a mesma tecnologia do pagamento por aproximação. A etiqueta não tem bateria: ela é alimentada pelo próprio celular no momento da leitura.
NDEF	Um <i>formato</i> padrão para organizar mensagens dentro da etiqueta — como o "formato de envelope" de uma carta. Não é, por si só, segurança.
UID	O identificador de fábrica do chip, parecido com um número de série.
SDM	<i>Secure Dynamic Messaging</i> : recurso da NTAG 424 DNA que gera, a cada leitura, uma mensagem nova com um contador e um código de autenticação.

Estratégia 1 — NDEF estático

Um bilhete fixo guardado dentro da etiqueta

Como funciona

No cadastro, grava-se na etiqueta uma **referência fixa** à encomenda — por exemplo, um código como "PEDIDO-1234". Quando o celular lê a etiqueta, o aplicativo pega esse código e o servidor procura a encomenda correspondente. O conteúdo é sempre o mesmo, em todas as leituras.



Analogia: é como um bilhete escrito à mão colado na caixa. Qualquer pessoa que leia o bilhete pode escrever outro igual e colar em outra caixa. Ninguém consegue diferenciar a cópia do original só olhando o bilhete.

Como o sistema valida

A única conferência é: *"esse código existe no cadastro?"*. Não há nenhuma prova matemática (criptográfica) de que o texto veio da etiqueta verdadeira. A escrita da etiqueta é bloqueada por chave, o que impede alguém de **alterar** o bilhete original — mas não impede de **copiá-lo**.

O que ela consegue

- ✓ Identificar a encomenda de forma simples e barata.
- ✓ Funcionar em praticamente qualquer etiqueta NFC.
- ✓ Servir de **linha de base**: mostra quanta segurança vem só das regras do servidor.

O que ela NÃO consegue

- ✗ Detectar uma cópia: o conteúdo pode ser copiado para outra etiqueta.
- ✗ Provar que a leitura veio da etiqueta verdadeira.
- ✗ Detectar a reutilização de uma leitura antiga — o conteúdo é sempre igual.

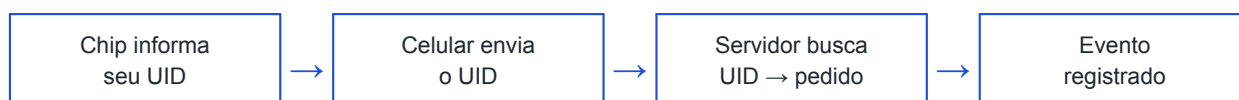
Por que ela está no estudo? Justamente por ser fraca. Ela mostra, na prática, o que acontece quando o sistema confia apenas em um conteúdo fixo. Demonstrar essa vulnerabilidade faz parte dos resultados esperados do trabalho.

Estratégia 2 — Associação por UID

O "número de série" de fábrica do chip

Como funciona

Todo chip sai de fábrica com um identificador, o **UID**. No cadastro, o sistema anota: "o chip de UID 04:A1:B2... pertence ao pedido 1234". Na leitura, o celular obtém o UID diretamente do chip (não do texto guardado nele) e o servidor procura qual encomenda está ligada àquele número. Para o teste, a opção de UID aleatório da etiqueta fica desligada, para que o número seja sempre o mesmo.



Analogia: é como identificar um carro pelo número do chassi em vez de pela placa. Trocar a placa (o conteúdo) é fácil; o chassi vem de fábrica. Mas, se a pessoa que faz a vistoria simplesmente *acredita* no número que alguém fala em voz alta, o chassi não ajuda nada.

Como o sistema valida

O servidor confere se o UID recebido está cadastrado. Se alguém copiar o conteúdo para outra etiqueta, essa outra etiqueta terá um UID diferente — e um aplicativo honesto vai perceber a diferença. Isso já é uma melhora em relação à estratégia 1.

O ponto fraco é que o UID é um **número público, não um segredo**. O servidor não "vê" o chip: ele só recebe o número que o aplicativo enviou. Um aplicativo adulterado pode simplesmente **digitar** o UID da etiqueta verdadeira e enviá-lo. Além disso, existem etiquetas e equipamentos capazes de imitar um UID.

O que ela consegue

- ✓ Detectar uma cópia simples do conteúdo feita em outra etiqueta (com app honesto).
- ✓ Usar um dado que vem de fábrica e não fica no texto gravável.

O que ela NÃO consegue

- ✗ Impedir um app adulterado de enviar um UID falso ao servidor.
- ✗ Oferecer prova criptográfica: UID é identificação, não autenticação.
- ✗ Detectar a reutilização de uma leitura — o UID é sempre o mesmo.

Resumo: o UID dificulta cópias simples, mas consultar um cadastro a partir dele **não é**, por si só, uma verificação de que a informação veio da etiqueta verdadeira.

Estratégia 3 — Mensagem dinâmica autenticada (SDM)

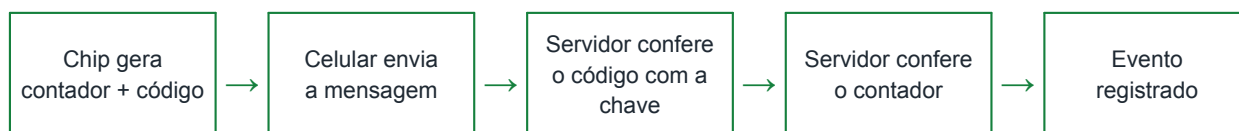
Um código novo a cada leitura, que só a etiqueta verdadeira sabe gerar

Como funciona

A etiqueta NTAG 424 DNA guarda uma **chave secreta** que ninguém consegue ler de fora. O servidor também conhece essa chave. A cada leitura, o chip monta uma mensagem nova com duas coisas:

- um **contador**, que aumenta a cada leitura (1, 2, 3...);
- um **código de autenticação** (chamado CMAC), calculado com a chave secreta a partir dos dados da mensagem.

O servidor refaz o mesmo cálculo com a chave. Se o código bater, ele sabe que a mensagem foi produzida por aquela etiqueta e não foi alterada no caminho. Depois, ele confere o contador para não aceitar a mesma mensagem duas vezes.



Analogia: é como o token do banco que gera um número diferente a cada vez. Mesmo que alguém veja o número de hoje, ele não serve para amanhã, e não dá para adivinhar o próximo sem ter o dispositivo. Aqui, cada mensagem da etiqueta é um "bilhete de uso único".

Como o sistema valida (em 3 perguntas)

1. A mensagem é autêntica?	O código confere com a chave daquela etiqueta? Se não, a mensagem foi alterada ou é falsa — rejeita.
2. Ela já foi usada?	Aquele contador já apareceu antes para essa etiqueta? Se sim, é reaproveitamento — rejeita, mesmo que venha com outro número de evento.
3. A operação é permitida?	O operador tem permissão e a etapa faz sentido (ex.: não dá para "entregar" antes de "coletar")? Essa pergunta é das regras de negócio, não da etiqueta.

O que ela consegue

- ✓ Detectar cópia: sem a chave, não é possível gerar códigos válidos.
- ✓ Detectar alteração dos dados protegidos pelo código.
- ✓ Detectar a reutilização de uma mensagem já usada.
- ✓ Rejeitar um app que tenta inventar a mensagem.

O que ela NÃO consegue

- ✗ Garantir que o tipo de operação, horário ou GPS enviados pelo app são verdadeiros (eles ficam fora do código).
- ✗ Distinguir uma leitura honesta atrasada (feita offline) de uma mensagem guardada de propósito e apresentada depois pela primeira vez.
- ✗ Perceber se a etiqueta foi descolada e colada em outra caixa.

Custo da segurança: exige etiquetas mais caras, configuração das chaves em cada etiqueta, guarda dessas chaves no servidor e mais complexidade na implementação.

4. E quando o celular está sem internet?

Em muitos locais a conexão cai. Por isso, o aplicativo **guarda a leitura no próprio celular** e mostra ao operador algo como "capturado, aguardando verificação". Quando a internet volta, ele envia tudo ao servidor. Nesse período, a leitura ainda **não** está validada — quem valida é o servidor, depois.

Isso cria um problema para a estratégia 3. Vários celulares podem voltar a ficar on-line em momentos diferentes, e as mensagens podem chegar **fora de ordem**. Exemplo: a leitura de contador 102 chega antes da leitura de contador 101. O fabricante da etiqueta recomenda rejeitar contadores fora de ordem — mas isso pode descartar leituras honestas feitas offline. Por isso, o trabalho compara duas regras (políticas):

Política	Regra	Vantagem	Desvantagem
Estrita	Só aceita como nova uma mensagem válida cujo contador seja maior que o maior já visto.	Bloqueia qualquer mensagem mais antiga que a última recebida.	Pode rejeitar leituras honestas que chegaram atrasadas.
Registro tardio	Aceita guardar uma mensagem válida ainda não usada, mesmo com contador menor, marcando-a como tardia .	Preserva o histórico e deixa o atraso visível.	A mensagem tardia não autoriza sozinha uma nova movimentação.

Exemplo: uma leitura antiga de "coletado" chega depois que a encomenda já foi marcada como "entregue". Ela pode entrar no histórico, mas a encomenda **não volta** para "coletado". Preservar uma informação é diferente de aceitar a movimentação que ela pede.

5. Regras que valem para as três estratégias

Algumas proteções não dependem da etiqueta e são iguais para todas as estratégias. Assim, o experimento consegue separar o que é mérito da etiqueta e o que é mérito do servidor:

- **Operador autenticado e autorizado:** só quem tem permissão pode registrar a operação.
- **Sem duplicar eventos:** cada leitura ganha um identificador único no celular. Se o mesmo evento for reenviado (por exemplo, porque a resposta se perdeu na rede), o servidor devolve a decisão anterior em vez de criar outra movimentação. Mesmo identificador com conteúdo diferente gera conflito.
- **Ordem das etapas:** cadastrado → coletado → recebido → entregue. Se um evento chegar antes do anterior, fica pendente até o anterior chegar.

6. Comparação lado a lado

	1. NDEF estático	2. UID	3. SDM
O dado muda a cada leitura?	Não	Não	Sim
Tem prova criptográfica?	Não	Não	Sim
Detecta cópia do conteúdo?	Não	Em parte (só com app honesto)	Sim
Resiste a um app que inventa dados da etiqueta?	Não	Não	Sim
Detecta reutilização de uma leitura?	Não	Não	Sim
Garante operação, horário e GPS informados?	Não	Não	Não
Detecta etiqueta trocada de caixa?	Não	Não	Não
Complexidade e custo	Baixos	Baixos	Altos (chaves, configuração)

7. Como as estratégias serão testadas

O experimento simula situações normais e tentativas de fraude, sempre com as mesmas etiquetas passando pelas três estratégias:

Cenário	O que se faz
Leitura normal	Ler a etiqueta certa, com operador autorizado, com e sem internet.
Cópia / UID falso	Copiar o conteúdo para outra etiqueta; enviar um UID falso ao servidor.
Alteração de dados	Modificar a mensagem da etiqueta; alterar só os dados do aplicativo.
Reutilização	Reapresentar uma mensagem SDM já usada, com outro número de evento.
Primeira apresentação atrasada	Guardar uma mensagem legítima nunca enviada e usá-la depois.
Duplicação	Reenviar o mesmo evento e disputar a mesma mensagem ao mesmo tempo.
Fora de ordem	Inverter a ordem de envio após reconectar e comparar as duas políticas.
Troca física	Mover uma etiqueta intacta de uma caixa para outra.

Serão medidos: quantas fraudes foram aceitas por engano, quantas leituras honestas foram rejeitadas, quantos registros foram preservados e o tempo de leitura, verificação e sincronização.

8. Resumo final

NDEF estático	Diz " <i>qual é a encomenda</i> ", mas qualquer um pode copiar. Útil como ponto de comparação.
UID	Usa um número de fábrica, o que atrapalha cópias simples, mas o número é público e pode ser informado falsamente ao servidor.
SDM	Gera uma prova nova a cada leitura, que só a etiqueta verdadeira sabe produzir. É a única que detecta cópia e reutilização — ao custo de mais complexidade.

O limite que vale para todas

Nenhuma das três estratégias prova o que está *dentro* da caixa nem que a movimentação aconteceu de fato no mundo real. A etiqueta mais segura prova apenas que **a mensagem veio dela e não foi reaproveitada**. Se alguém descolar a etiqueta e colar em outra caixa, a leitura continua válida. O trabalho deixa esses limites explícitos para que o sistema não prometa garantias que não consegue oferecer.

Principais referências

ALZHRANI, N.; BULUSU, N. Securing pharmaceutical and high-value products against tag reapplication attacks using NFC tags. IEEE SMARTCOMP, 2016.

GOOGLE. Build an offline-first app; Tag. Android Developers, 2026.

NFC FORUM. NFC Data Exchange Format (NDEF) Technical Specification.

NXP SEMICONDUCTORS. NTAG 424 DNA: Secure NFC T4T compliant IC (NT4H2421Gx), 2019.

NXP SEMICONDUCTORS. NTAG 424 DNA and NTAG 424 DNA TagTamper features and hints (AN12196), 2025.

WOHLIN, C. et al. Experimentation in software engineering. Springer, 2024.